

**MEDICARE CONNECT (PTY) LTD
INTERNAL AUDIT CHARTER & PROGRAM**

Aligned to ISO/IEC 27001:2022 Clause 9.2 and ISO 19011:2018

Classification: Internal

Version : 1.0

Date: March 2026

Author: Patrick Mohlala, Lead Internal Auditor (Portfolio Context)

Approved by: Chief Executive Officer & Board Audit Committee

1. PURPOSE & AUTHORITY

The Internal Audit function derives its authority from the Board of Directors. This Charter authorizes the Internal Audit team to review and evaluate the adequacy, effectiveness, and efficiency of MediCare Connect's Information Security Management System (ISMS) and POPIA data protection controls.

2. INDEPENDENCE & OBJECTIVITY

To maintain strict audit independence (aligned to ISO 19011 Principle 4):

- Internal Auditors shall remain objective and impartial.
- Auditors shall not directly audit activities or controls they have personally designed or implemented in operational roles.
- Audit findings shall be reported directly to the CEO and Board Audit Committee without management filtering.

3. SCOPE OF AUDIT ACTIVITIES

The audit function is empowered to access:

- All MediCare Connect information systems, cloud tenancies (AWS/M365), and physical premises.
- All personnel, clinical staff, contractors, and third-party vendor documentation.
- All risk registers, policy documentation, incident logs, and technical configuration files.

4. AUDIT METHODOLOGY (ISO 19011)

Audits shall be conducted according to the following principles:

- Evidence-based approach: Audit conclusions must be based on verifiable objective evidence.
- Fair presentation: Audit reporting must accurately reflect audit activities and findings.
- Due professional care: Application of diligence and judgment in auditing.
- Confidentiality: Security of patient and organizational information reviewed during audits.

5. 3-YEAR AUDIT UNIVERSE & SCHEDULE

YEAR 1 (Current Focus - Capstone Scope):

- ISMS Scope & Policy Governance (ISO Clause 4, 5, 6, 7)
- High-Risk Annex A Controls: Access Control, Cryptography, Endpoint Security
- POPIA Section 19 & 55 Compliance Baseline
- Third-Party Vendor Security (A.5.19–A.5.22)
- Incident Response Readiness (A.5.24–A.5.28 & POPIA Sec 22)

YEAR 2:

- Business Continuity & ICT Readiness (ISO Clause 8 & Control A.5.30)
- Physical & Environmental Security (Control A.7.1–A.7.14)
- Cloud Infrastructure Deep-Dive (AWS Technical Control Operating Effectiveness)

YEAR 3:

- Full ISMS Recertification Preparation Audit
- Human Resource Security & Security Awareness Program Effectiveness
- Data Subject Access Request (DSAR) & POPIA Section 18 Operations

Document Control

Approved by : CEO & Board Audit Committee

Date : March 2026

Status : Final
Next Review: March 2027